Testing Lab: Authentication & Two-Factor Authentication (2FA)

Overview

This testing lab covers the authentication system including login, logout, and Two-Factor Authentication (TOTP) features. The 2FA implementation uses RFC 6238 standard with QR code generation and recovery codes.

Test Environment Setup

Prerequisites

- FileFlow application running on `http://localhost:3000`
- Backend API running on `http://localhost:8080`
- Test user accounts created in the admin panel
- Access to an authenticator app (Google Authenticator, Authy, Microsoft Authenticator, or similar)

Reset Procedures

1. Clear browser cookies/localStorage: `localStorage.clear()` in console
2. Reset user 2FA status: Delete user's 2FA configuration from backend storage
3. Restart application: Ensure clean state before each test cycle

---

Feature 1: Basic Login Authentication

Test 1.1: Valid Login

Objective: Verify user can login with correct credentials
Steps: 1. Navigate to login page 2. Enter valid username and password 3. Click "Login" button

Expected Results: - ✓ User is authenticated - ✓ Redirected to file manager dashboard - ✓ JWT token is stored in HTTP-only cookie - ✓ User info displays in sidebar (username visible) - ✓ Navigation bar shows "Logout" option

Test Data: - Username: `testuser` - Password: `TestPassword123!`

Test 1.2: Invalid Username

Objective: Verify login fails with non-existent username
Steps: 1. Navigate to login page 2. Enter non-existent username: `nonexistentuser` 3. Enter any password 4. Click "Login" button

Expected Results: - ✓ Login fails - ✓ Error message displayed: "Invalid credentials" - ✓ Generic error (doesn't reveal user existence) - ✓ User remains on login page - ✓ No JWT token created

---

Test 1.3: Invalid Password

Objective: Verify login fails with incorrect password
Steps: 1. Navigate to login page 2. Enter valid username: `testuser` 3. Enter incorrect password: `WrongPassword123!` 4. Click "Login" button

Expected Results: - ✓ Login fails - ✓ Error message displayed: “Invalid credentials” - ✓ Generic error message (no password hint) - ✓ User remains on login page - ✓ No JWT token created

---

Test 1.4: Empty Credentials

Objective: Verify form validation for empty fields
Steps: 1. Navigate to login page 2. Leave username empty 3. Leave password empty 4. Click “Login” button

Expected Results: - ✓ Form validation error shown - ✓ Required field indicators displayed - ✓ No API call made - ✓ User remains on login page

---

Test 1.5: SQL Injection Attempt

Objective: Verify protection against SQL injection attacks
Steps: 1. Navigate to login page 2. Enter username: `admin' --` 3. Enter password: `' OR '1'='1` 4. Click “Login” button

Expected Results: - ✓ Login fails safely - ✓ Generic error message displayed - ✓ No error stack trace revealed - ✓ Backend logs the suspicious attempt - ✓ Application remains stable

---

Feature 2: Two-Factor Authentication (TOTP) Setup

Test 2.1: Enable 2FA with QR Code

Objective: Verify 2FA can be enabled with QR code scanning
Steps: 1. Login to FileFlow with valid credentials 2. Navigate to Settings > Security 3. Click “Enable Two-Factor Authentication” 4. View QR code dialog 5. Scan QR code with authenticator app 6. Copy TOTP code from authenticator app 7. Paste TOTP code in verification field 8. Click “Confirm”

Expected Results: - ✓ QR code displays correctly - ✓ QR code contains valid seed (secret) - ✓ Authenticator app accepts scan - ✓ TOTP codes are generated correctly - ✓ Verification succeeds with correct code - ✓ Recovery codes displayed and downloadable - ✓ “2FA Enabled” status shown - ✓ Success message: “Two-factor authentication has been enabled”

Verification: - Scan QR code with multiple authenticator apps - Verify consistent TOTP generation across apps - Test that codes change every 30 seconds

---

Test 2.2: Recovery Codes Generation

Objective: Verify recovery codes are properly generated and secured
Steps: 1. Complete 2FA setup 2. Review recovery codes displayed 3. Download or copy recovery codes 4. Store in secure location (for testing only)

Expected Results: - ✓ 10 recovery codes generated - ✓ Each code is unique - ✓ Codes are bcrypt hashed in database (not plaintext) - ✓ Codes are displayed once only (not retrievable later) - ✓ Download option available (as text file) - ✓ Warning displayed: “Store these codes securely” - ✓ Each code is valid for single use

Code Format Verification: - Recovery codes should be format: `XXXX-XXXX` (8 characters with hyphen) - Can be case-insensitive in input

---

Test 2.3: Cancel 2FA Setup

Objective: Verify user can cancel 2FA setup without enabling it
Steps: 1. Navigate to Settings > Security 2. Click “Enable Two-Factor Authentication” 3. View QR code dialog 4. Click “Cancel” button

Expected Results: - ✓ Dialog closes - ✓ 2FA remains disabled - ✓ No seed/secret created - ✓ User returns to settings page - ✓ “Enable 2FA” option still available

---

Feature 3: TOTP Verification During Login

Test 3.1: Login with Valid TOTP Code

Objective: Verify successful login with 2FA enabled
Steps: 1. With 2FA enabled, logout 2. Navigate to login page 3. Enter valid username and password 4. Click “Login” 5. TOTP verification screen appears 6. Generate TOTP code from authenticator app 7. Enter TOTP code 8. Click “Verify”

Expected Results: - ✓ Login redirects to TOTP verification screen - ✓ TOTP screen has masked code entry field - ✓ Code verification succeeds - ✓ User is redirected to dashboard - ✓ JWT token created with full auth - ✓ Session established successfully

---

Test 3.2: Invalid TOTP Code

Objective: Verify verification fails with incorrect code
Steps: 1. Reach TOTP verification screen 2. Enter incorrect TOTP code (e.g., `000000`) 3. Click “Verify”

Expected Results: - ✓ Verification fails - ✓ Error message: “Invalid authentication code” - ✓ User remains on verification screen - ✓ Can retry with correct code - ✓ No session created - ✓ Failed attempt logged

---

Test 3.3: Expired TOTP Code

Objective: Verify time-window tolerance for TOTP
Steps: 1. Generate TOTP code 2. Wait 35+ seconds (to exceed 30-second window + tolerance) 3. Enter the previously generated code 4. Click “Verify”

Expected Results: - ✓ Verification may fail or show tolerance message - ✓ Current code accepted (±1 time window) - ✓ Old codes rejected - ✓ User instructed to use current code

---

Test 3.4: Empty TOTP Code

Objective: Verify form validation for empty code
Steps: 1. Reach TOTP verification screen 2. Leave code field empty 3. Click “Verify” button

Expected Results: - ✓ Form validation error shown - ✓ Required field indicator displayed - ✓ No API call made - ✓ User remains on verification screen

---

Feature 4: Recovery Code Authentication

Test 4.1: Login with Valid Recovery Code

Objective: Verify recovery codes work when TOTP app unavailable
Steps: 1. With 2FA enabled, logout 2. Navigate to login page 3. Enter valid credentials 4. TOTP verification screen appears 5. Click “Use recovery code instead” 6. Enter a valid unused recovery code 7. Click “Verify”

Expected Results: - ✓ Recovery code field appears - ✓ Code is accepted - ✓ User is logged in successfully - ✓ Recovery code marked as used - ✓ Same code cannot be used again - ✓ Session established

---

Test 4.2: Invalid Recovery Code

Objective: Verify invalid recovery code is rejected
Steps: 1. Reach recovery code screen 2. Enter invalid code: XXXX-XXXX 3. Click “Verify”

Expected Results: - ✓ Verification fails - ✓ Error message: “Invalid recovery code” - ✓ User remains on screen - ✓ Can retry - ✓ Failed attempt logged

---

Test 4.3: Exhausted Recovery Codes

Objective: Verify behavior when all recovery codes used
Steps: 1. Use all 10 recovery codes for login attempts 2. Attempt to use 11th code

Expected Results: - ✓ All 10 codes can be used (one per login) - ✓ Codes cannot be reused - ✓ After 10 uses, recovery codes exhausted - ✓ User should regenerate codes or reset 2FA

Feature 5: 2FA Management

Test 5.1: Disable 2FA

Objective: Verify user can disable 2FA
Steps: 1. Login to FileFlow 2. Navigate to Settings > Security 3. Click “Disable Two-Factor Authentication” 4. Enter current password for confirmation 5. Enter a current TOTP code from the authenticator app (or an unused recovery code) 6. Click “Confirm”

Expected Results: - ✓ Password **and** a second-factor code required (`POST /api/auth/2fa/disable` with `password` and `code`) - ✓ 2FA disabled - ✓ Session rotated: this browser stays logged in with a new cookie, all other sessions of the user are revoked - ✓ Recovery codes invalidated - ✓ Status shows “2FA Disabled” - ✓ Success message displayed - ✓ Next login doesn’t require TOTP

Test 5.2: Regenerate Recovery Codes

Objective: Verify recovery codes can be regenerated
Steps: 1. Navigate to Settings > Security 2. Click “Regenerate Recovery Codes” 3. Enter current password and a current TOTP code (or an unused recovery code) 4. Confirm action 5. View new recovery codes

Expected Results: - ✓ Password **and** second-factor code required; the request fails without either - ✓ 10 new recovery codes generated - ✓ Old codes invalidated - ✓ New codes different from previous - ✓ All new codes in unused state - ✓ Download option available

---

Test 5.3: View 2FA Status

Objective: Verify 2FA status is clearly displayed
Steps: 1. Navigate to Settings > Security 2. View 2FA section

Expected Results: - ✓ Current 2FA status displayed clearly - ✓ Last enabled/disabled timestamp shown - ✓ Recovery codes remaining count shown - ✓ Appropriate action buttons available - ✓ QR code not visible (only on setup)

Test 5.4: 2FA Changes Rejected Without Valid Step-Up

Objective: Verify a stolen session or a stolen password alone cannot change an active second factor
Steps: 1. With 2FA enabled, open Settings > Security 2. Try "Disable 2FA" with the correct password and a wrong code (`000000`) 3. Try again with a wrong password and a valid TOTP code 4. Repeat steps 2–3 for "Regenerate Recovery Codes" 5. Continue failing until 5 failures in total

Expected Results: - ✓ Each attempt rejected with HTTP 400 and the same generic message ("Invalid password or code"), which does not reveal which factor was wrong - ✓ 2FA stays enabled; existing recovery codes stay valid - ✓ After 5 failures, further attempts return HTTP 429 for 15 minutes (shared 2FA lockout) - ✓ Failures recorded in the audit log (`2fa_disable_failed`, `2fa_regen_failed`)

Test 5.5: Setup Refused While 2FA Is Active

Objective: Verify an active secret cannot be replaced by re-running setup
Steps: 1. With 2FA enabled, send `POST /api/auth/2fa/setup` with the session cookie (e.g. from DevTools or `curl`) 2. Send `POST /api/auth/2fa/confirm` with any code

Expected Results: - ✓ Both requests rejected with HTTP 400 ("2FA is already enabled") - ✓ Existing authenticator codes keep working - ✓ To change authenticator, the user must disable 2FA first (Test 5.1) and enable it again

---

Test 5.6: 2FA Changes Revoke Other Sessions

Objective: Verify enabling or disabling 2FA logs out every other session
Steps: 1. Login as the same user in two browsers (A and B) 2. In browser A, enable 2FA (Test 2.1) 3. In browser B, refresh the file list 4. Login again in B, then disable 2FA in A (Test 5.1) and refresh B

Expected Results: - ✓ Browser A stays logged in after each change (it receives a new session cookie) - ✓ Browser B is logged out after each change (old token rejected with 401)

Feature 6: Session Management

Test 6.1: Logout

Objective: Verify logout clears session
Steps: 1. Login with valid credentials (with or without 2FA) 2. Click "Logout" button 3. Verify redirect to login page 4. Try to access protected route

Expected Results: - ✓ `POST /api/auth/logout` returns HTTP 200 - ✓ Both cookies cleared by the response: `fileflow_token` and `fileflow_2fa_pending` - ✓ Session ended - ✓ User redirected to login page - ✓ Accessing `/files` redirects to login - ✓ No user info in localStorage

---

Test 6.2: Session Timeout

Objective: Verify sessions expire after inactivity
Steps: 1. Login to FileFlow 2. Set system clock ahead 30+ minutes (or wait) 3. Attempt to perform action (e.g., list files)

Expected Results: - ✓ Expired token detected - ✓ User redirected to login page - ✓ Session message: "Session expired. Please login again." - ✓ All actions blocked until re-login

---

Test 6.3: Logout Without a Valid Session

Objective: Verify logout always clears cookies, even when the session is already invalid
Steps: 1. Login, then revoke the session from another browser ("Log out everywhere") or wait for expiry 2. In the first browser, click "Logout" (or send `POST /api/auth/logout` with the stale cookie) 3. Send `POST /api/auth/logout` with no cookie at all

Expected Results: - ✓ Both requests return HTTP 200 (never 500, never 401) - ✓ `Set-Cookie` headers clear `fileflow_token` and `fileflow_2fa_pending` - ✓ A `logout` audit entry is written only when the presented token was valid

---

Test 6.4: Token of a Deleted Account Not Reused

Objective: Verify a session issued to a deleted account does not become valid for a new account with the same name
Steps: 1. Login as `tempuser` in browser A and keep the session open 2. As admin, delete `tempuser`, then recreate a user named `tempuser` 3. In browser A, refresh the file list

Expected Results: - ✓ Browser A's old session is rejected (401) and redirected to login - ✓ The new `tempuser` can log in normally with its own password

---

Performance & Security Tests

Test 7.1: Login Rate Limiting

Objective: Verify protection against brute force attacks
Steps: 1. Attempt login 10 times with wrong password (rapid succession) 2. Verify response after multiple failures

Expected Results: - ✓ After 5 failed attempts, further attempts return HTTP 429 (even with the correct password) - ✓ Error message: "Too many attempts. Try again later." - ✓ Locked for this client: the IP (5 failures) and the (username, IP) pair (5 failures) - ✓ Lockout duration: 15 minutes - ✓ Lockouts are held in memory: restarting the server clears them

---

Test 7.4: Another Client Cannot Lock an Account

Objective: Verify a third party cannot lock a known account with a few bad passwords
Steps: 1. From client A (IP 1), fail login for `testuser` 5 times 2. From client B (IP 2), login as `testuser` with the correct password

Expected Results: - ✓ Client A is locked out (HTTP 429) - ✓ Client B logs in successfully: the lockout is per (username, IP), not per account

Note: To simulate two IPs locally, run behind a reverse proxy with `TRUST_PROXY_HEADERS=true` and vary `X-Forwarded-For`, or use two hosts.

Test 7.5: Account-Wide Lockout Threshold

Objective: Verify guessing spread over many IPs is still stopped
Steps: 1. Using at least 10 different IPs, fail login for `testuser` 50 times in total (at most 4 per IP so no per-IP lock triggers) 2. Login as `testuser` with the correct password from a fresh IP 3. Repeat with a successful login between failures (e.g. after 30 failures)

Expected Results: - ✓ After 50 failures across all IPs, the account is locked for every client (HTTP 429) for 15 minutes - ✓ A successful login in between does **not** reset the account-wide count; it expires on its own 15 minutes after the last failure

---

Test 7.2: HTTPS/TLS Verification

Objective: Verify credentials transmitted securely
Steps: 1. Verify login page uses HTTPS 2. Check certificate validity 3. Use browser dev tools to inspect request headers

Expected Results: - ✓ All auth requests use HTTPS - ✓ Valid SSL/TLS certificate - ✓ No credentials in URL or logs - ✓ Secure headers present: - `Strict-Transport-Security` - `X-Content-Type-Options: nosniff`

Test 7.3: Cookie Security

Objective: Verify JWT token cookie is secure
Steps: 1. Login to FileFlow 2. Open browser DevTools > Application > Cookies 3. Examine JWT cookie properties

Expected Results: - ✓ Cookie name: `fileflow_token` - ✓ `HttpOnly` flag: ✓ (inaccessible via JavaScript) - ✓ `Secure` flag: ✓ (HTTPS only) - ✓ `SameSite`: `Strict` (CSRF protection) - ✓ Expiry: 7 days or configured value - ✓ No extra cookies containing sensitive data

---

Test Results Summary

Test ID	Test Name	Status	Notes
1.1	Valid Login	☐	
1.2	Invalid Username	☐	
1.3	Invalid Password	☐	
1.4	Empty Credentials	☐	
1.5	SQL Injection	☐	
2.1	Enable 2FA	☐	
2.2	Recovery Codes	☐	
2.3	Cancel 2FA	☐	
3.1	Valid TOTP	☐	
3.2	Invalid TOTP	☐	
3.3	Expired TOTP	☐	
3.4	Empty TOTP	☐	
4.1	Recovery Code	☐	

Test ID	Test Name	Status	Notes
4.2	Invalid Recovery	☐	
4.3	Exhausted Codes	☐	
5.1	Disable 2FA	☐	
5.2	Regenerate Codes	☐	
5.3	2FA Status	☐	
5.4	2FA Step-Up Rejection	☐	
5.5	Setup Refused When Active	☐	
5.6	2FA Change Revokes Sessions	☐	
6.1	Logout	☐	
6.2	Session Timeout	☐	
6.3	Logout Without Session	☐	
6.4	Deleted Account Token	☐	
7.1	Rate Limiting	☐	
7.2	HTTPS/TLS	☐	
7.3	Cookie Security	☐	
7.4	Lockout Isolation	☐	
7.5	Account-Wide Lockout	☐	

Bug Report Template

Use this template for any issues found during testing:

```
Title: [Brief description]
Severity: [Critical/High/Medium/Low]
Test ID: [Corresponding test ID]
Steps to Reproduce:
1. [First step]
2. [Second step]
Expected Result:
[What should happen]
Actual Result:
[What actually happens]
Screenshots: [Attach if applicable]
Environment: [Browser, OS, version]
```

Sign-Off

- **Tester Name**: _____
- **Test Date**: _____
- **Total Tests**: 30
- **Passed**: ____
- **Failed**: ____
- **Blocked**: ____

Conclusion: ☐ Ready for Production | ☐ Needs Fixes | ☐ Blocked

---

Version History

Date	Version	Changes	Author
2024-05-05	1.0	Initial lab	Driss OUAAZIZ
2026-10-27	1.1	2FA disable/regenerate need password + code; setup refused when active; session rotation; logout always clears cookies; lockout per IP, per (user, IP) and per account (50); deleted-account tokens; cookie name fixed; tests 5.4–5.6, 6.3, 6.4, 7.4, 7.5 added	Driss OUAAZIZ